
Tour Blog

Sri Lanka Travel Information Platform

Technical Report

A comprehensive explanation of every component
of the full-stack web application

Author: UpekaFernando
Repository: UpekaFernando/tour_blog_info_final
Frontend: React 18 + Vite + Material-UI
Backend: Node.js + Express + Sequelize
Database: MySQL 8.0
DevOps: Docker, Jenkins, Terraform, AWS
Date: March 23, 2026

Contents

1	Project Overview	4
1.1	Purpose and Goals	4
1.2	Technology Stack	4
1.3	High-Level Architecture	5
1.4	Repository Root Structure	5
2	Frontend Application (client/)	7
2.1	Overview	7
2.2	Key Configuration Files	7
2.2.1	package.json — Dependencies and Scripts	7
2.2.2	vite.config.js — Build Tool Configuration	7
2.2.3	.env and .env.production — Environment Variables	8
2.2.4	eslint.config.js — Code Quality	8
2.3	Dockerfile_frontend — Multi-Stage Docker Build	8
2.4	nginx.conf — Production Web Server	9
2.5	Source Code Structure (src/)	9
2.5.1	main.jsx — Entry Point	9
2.5.2	App.jsx — Application Root	10
2.5.3	AuthContext.jsx — Authentication State Management	11
2.5.4	utils/api.js — API Service Layer	11
2.6	Page Components (pages/)	12
2.7	Shared Components (components/)	13
2.7.1	Header.jsx	13
2.7.2	Footer.jsx	13
2.7.3	DestinationCard.jsx	13
2.7.4	SriLankaMap.jsx	14
3	Backend Server (server/)	15
3.1	Overview	15
3.2	server.js — Application Entry Point	15
3.3	config/database.js — Database Configuration	16
3.4	Database Models (models/)	17
3.4.1	User Model	17
3.4.2	District Model	17
3.4.3	Destination Model	17
3.4.4	Comment Model	18
3.4.5	Rating Model	18
3.4.6	LocalService Model	18
3.4.7	TravelGuide Model	18

3.4.8	Model Relationships	18
3.5	Controllers (controllers/)	19
3.5.1	UserController.js	19
3.5.2	destinationController.js	20
3.5.3	districtController.js	20
3.5.4	commentController.js	20
3.5.5	ratingController.js	20
3.5.6	localServiceController.js	20
3.5.7	travelGuideController.js	20
3.5.8	weatherController.js	21
3.6	Routes (routes/)	21
3.7	Middleware (middleware/)	21
3.7.1	authMiddleware.js — JWT Verification	21
3.7.2	uploadMiddleware.js — File Upload Handling	22
3.8	services/weatherService.js — External Weather Integration	22
3.9	Dockerfile_backend	22
4	Database Design	24
4.1	Overview	24
4.2	Entity-Relationship Summary	24
4.3	Table Definitions	25
4.4	Data Seeding	25
5	Docker and Containerisation	27
5.1	Overview	27
5.2	docker-compose.yml	27
5.3	.dockerignore	28
6	CI/CD Pipeline (Jenkinsfile)	29
6.1	Overview	29
6.2	Environment Variables	29
6.3	Pipeline Stages Explained	29
6.3.1	Stage 1: Prepare	29
6.3.2	Stage 2: Build Backend	30
6.3.3	Stage 3: Build Frontend	30
6.3.4	Stage 4: Push to Docker Hub	31
6.3.5	Stage 5: Install Terraform	31
6.3.6	Stages 6–9: Terraform Init, State Cleanup, Plan, Apply	32
7	Infrastructure as Code (Terraform.tf)	33
7.1	Overview	33
7.2	Provider Configuration	33
7.3	Referenced Existing Resources	34
7.4	Managed Resources	34
7.5	Input Variables	34
7.6	Outputs	34
7.7	user-data-inline.sh — EC2 Bootstrap Script	35
7.8	cleanup-terraform-state.sh	35

8	Authentication and Security	36
8.1	Authentication Flow	36
8.2	Password Security	36
8.3	Security Headers (Nginx)	36
8.4	Security Considerations and Recommendations	37
9	Deployment Workflow	38
9.1	End-to-End Deployment Sequence	38
9.2	Local Development	38
9.3	Environment Variables Reference	39
10	Summary and Conclusions	40
10.1	What Has Been Built	40
10.2	Key Design Decisions	40
10.3	Future Improvements	41

Chapter 1

Project Overview

1.1 Purpose and Goals

Tour Blog is a full-stack web application designed for exploring, sharing, and managing information about tourist destinations in **Sri Lanka**. The platform enables:

- **Destination Discovery** — Users can browse an interactive map and a curated list of Sri Lankan destinations organised by district.
- **Community Contributions** — Authenticated users may add new destinations, post comments, and submit star ratings.
- **Local Services Directory** — Hotels, restaurants, tour operators, and transport services are catalogued with pricing tiers and contact details.
- **Travel Guides** — Step-by-step guides covering planning, budget travel, cultural etiquette, visa information, and emergency contacts.
- **Weather Information** — Live weather data via an external API, helping visitors plan their trips.
- **Photo Gallery** — A visual gallery of destination images uploaded by users.

1.2 Technology Stack

Table 1.1 summarises the technologies used across every layer of the system.

Table 1.1: Technology stack

Layer	Technology	Version / Notes
Frontend framework	React	18 (Vite build tool)
UI component library	Material-UI (MUI)	v7
Routing	React Router DOM	v7
HTTP client	Axios	v1.10
Mapping	Mapbox GL / react-map-gl	v3 / v8
Styling	Emotion + styled-components	v11 / v6
Backend framework	Express.js	v4.18
ORM	Sequelize	v6.37
Database	MySQL	8.0
Authentication	JSON Web Tokens	9.0
Password hashing	bcryptjs	2.4
File uploads	Multer	v2
Containerisation	Docker + Docker Compose	latest
Web server	Nginx (Alpine)	production frontend
CI/CD	Jenkins	Declarative Pipeline
Infrastructure	Terraform	1.7.0
Cloud provider	AWS (EC2, RDS, S3)	us-east-1

1.3 High-Level Architecture

The application follows a **three-tier architecture**:

1. **Presentation tier** — React Single-Page Application (SPA) served by Nginx inside a Docker container.
2. **Application tier** — Node.js/Express REST API server running in a separate Docker container, exposing endpoints on port 5000.
3. **Data tier** — AWS RDS MySQL 8.0 instance (identifier `tour-blog-db`) storing all persistent data.

Both Docker containers run on an AWS EC2 `t3.micro` instance. The frontend is also published as a static website to an **AWS S3 bucket** for high-availability access. A **Jenkins** CI/CD pipeline automates building, testing, and deploying new versions.

1.4 Repository Root Structure

Listing 1.1: Top-level directory layout

```

1 tour_blog_info_final/
2 |-- client/                # React frontend application
3 |-- server/                # Node.js/Express backend API
4 |-- Terraform.tf           # AWS infrastructure definition
5 |-- docker-compose.yml     # Local development orchestration
6 |-- Jenkinsfile            # CI/CD pipeline definition
7 |-- user-data-inline.sh    # EC2 bootstrap script

```

```
8 |-- cleanup-terraform-state.sh # Terraform state helper
9 |-- .dockerignore           # Docker build exclusions
10 |-- .gitignore              # Git exclusions
11 |-- README.md               # Project readme
```

Chapter 2

Frontend Application (client/)

2.1 Overview

The frontend is a **React 18 Single-Page Application** built with **Vite** as the build tool. It implements the complete user interface: navigation, destination browsing, user authentication, forms for adding/editing content, and an interactive Mapbox map of Sri Lanka.

The `client/` directory contains all source code, configuration, and Docker/Nginx files needed to build and serve the frontend both in development and in production.

2.2 Key Configuration Files

2.2.1 package.json — Dependencies and Scripts

`package.json` declares every JavaScript dependency required by the frontend and defines the npm scripts used for development, building, and linting. Key entries:

Listing 2.1: Frontend npm scripts

```
1 "dev":      "vite"           # Start Vite dev server (HMR)
2 "build":    "vite build"      # Production bundle
3 "lint":     "eslint ."        # Static code analysis
4 "preview":  "vite preview"    # Preview production build
    locally
```

Notable production dependencies include `react`, `react-dom`, `react-router-dom`, `@mui/material`, `axios`, `mapbox-gl`, and `react-map-gl`. The MUI icon package (`@mui/icons-material`) supplies the icon set used throughout the UI.

2.2.2 vite.config.js — Build Tool Configuration

Vite is configured as the module bundler for the React application. The `@vitejs/plugin-react` plugin enables:

- Fast Refresh (Hot Module Replacement) during development.

- JSX transformation without manual React imports.
- Optimised production bundles via Rollup under the hood.

2.2.3 .env and .env.production — Environment Variables

Runtime configuration is separated from code using environment files. Vite exposes only variables prefixed with `VITE_` to the browser bundle.

Listing 2.2: Example .env settings

```
1 VITE_API_URL=http://localhost:5000/api    # Backend API base
   URL
```

In production (built by Jenkins or Docker), `VITE_API_URL` is overridden via a build argument to point at the AWS EC2 instance: `http://<EC2_PUBLIC_IP>:5000/api`.

2.2.4 eslint.config.js — Code Quality

ESLint is configured with the React plugin and React Hooks plugin to enforce consistent code style, catch common React mistakes (e.g. missing dependency arrays in `useEffect`), and prevent common accessibility problems.

2.3 Dockerfile_frontend — Multi-Stage Docker Build

The frontend Docker image uses a **two-stage build** to keep the final image small (only Nginx and compiled static files are shipped):

Listing 2.3: Multi-stage Dockerfile_frontend logic

```
1 # Stage 1 -- Builder
2 FROM node:18-alpine AS builder
3 WORKDIR /app
4 COPY package*.json ./
5 RUN npm ci
6 COPY . .
7 ARG VITE_API_URL          # Injected at build time by Jenkins
8 ENV VITE_API_URL=$VITE_API_URL
9 RUN npm run build         # Outputs to /app/dist
10
11 # Stage 2 -- Production server
12 FROM nginx:alpine
13 COPY --from=builder /app/dist /usr/share/nginx/html
14 COPY nginx.conf /etc/nginx/conf.d/default.conf
15 EXPOSE 80
16 CMD ["nginx", "-g", "daemon off;"]
```

Why multi-stage? The `node:18-alpine` image (~300MB) is only needed to compile the app. The final `nginx:alpine` image is under 30MB and serves the compiled static files.

2.4 nginx.conf — Production Web Server

The Nginx configuration is tuned for a React SPA with the following important directives:

- **try_files \$uri \$uri/ /index.html** - Ensures all client-side routes fall back to index.html so React Router can handle navigation without 404 errors.
- **Gzip compression (gzip on)** - Reduces transfer sizes for HTML, CSS, and JavaScript files.
- **Cache headers** - Hashed asset filenames receive a 1-year Cache-Control: max-age for optimal browser caching.
- **Security headers** - X-Frame-Options: SAMEORIGIN, X-Content-Type-Options: nosniff, and X-XSS-Protection harden the frontend against common attacks.

2.5 Source Code Structure (src/)

Listing 2.4: Frontend source layout

```
1 src/  
2 |-- App.jsx           # Root component: theme + routing  
3 |-- main.jsx         # ReactDOM.render entry point  
4 |-- App.css / index.css  
5 |-- components/  
6 |   |-- Header.jsx  
7 |   |-- Footer.jsx  
8 |   |-- DestinationCard.jsx  
9 |   '-- SriLankaMap.jsx  
10 |-- pages/           # 16 page-level components  
11 |-- context/  
12 |   '-- AuthContext.jsx  
13 '-- utils/  
14   '-- api.js
```

2.5.1 main.jsx — Entry Point

main.jsx is the first file executed by Vite. It mounts the React application tree into the #root DOM element declared in index.html:

Listing 2.5: main.jsx

```
1 import React from 'react'  
2 import ReactDOM from 'react-dom/client'  
3 import App from './App.jsx'  
4 import './index.css'  
5  
6 ReactDOM.createRoot(document.getElementById('root')).render(  
7   <React.StrictMode>  
8     <App />  
9   </React.StrictMode>,  
10
```

10)

React.StrictMode activates additional runtime warnings during development (double-invocation of certain lifecycle methods) without affecting production behaviour.

2.5.2 App.jsx — Application Root

App.jsx is the highest-level React component. It performs three responsibilities:

1. **Theme definition** - A custom MUI theme applies the brand colours (dark cyan #006064 as primary, orange #FF9800 as secondary) site-wide.
2. **Authentication context** - Wraps the entire tree in <AuthProvider> so all descendant components can access login state.
3. **Route definitions** - Uses react-router-dom's <BrowserRouter> and <Routes> to declare all 16 routes of the application.

Listing 2.6: Simplified App.jsx routing structure

```

1 <BrowserRouter>
2   <AuthProvider>
3     <ThemeProvider theme={theme}>
4       <Header />
5       <Routes>
6         <Route path="/" element={<HomePage />} />
7         <Route path="/explore" element={<ExplorePage />} />
8         <Route path="/destinations/:id" element={<
DestinationPage />} />
9         <Route path="/district/:id" element={<DistrictPage
/>} />
10        <Route path="/add" element={<
AddDestinationPage />} />
11        <Route path="/edit/:id" element={<
EditDestinationPage />} />
12        <Route path="/login" element={<LoginPage />} />
13        <Route path="/register" element={<RegisterPage
/>} />
14        <Route path="/profile" element={<ProfilePage />} />
15        <Route path="/guides" element={<TravelGuidePage
/>} />
16        <Route path="/gallery" element={<
PhotoGalleryPage />} />
17        <Route path="/services" element={<
LocalServicesPage />} />
18        <Route path="/weather" element={<
WeatherClimatePage />} />
19        <Route path="/about" element={<AboutPage />} />

```

```
20     <Route path="/destinations" element={<  
    AllDestinationsPage />} />  
21     <Route path="*" element={<NotFoundPage  
    />} />  
22   </Routes>  
23   <Footer />  
24 </ThemeProvider>  
25 </AuthProvider>  
26 </BrowserRouter>
```

2.5.3 AuthContext.jsx — Authentication State Management

AuthContext implements the React Context API to share authentication state across the entire component tree without prop drilling.

- **State** - currentUser (user object or null), isAuthenticated (boolean), loading (boolean during initial check).
- **Persistence** - On mount, the context reads the JWT token and user object from localStorage to restore sessions after a page refresh.
- **login(userData, token)** - Stores the user and token in both React state and localStorage.
- **logout()** - Clears localStorage and resets state.
- **updateUser(userData)** - Allows the profile page to update the cached user object without re-login.

Any component that needs the current user can call useContext(AuthContext) (or the custom useAuth() hook).

2.5.4 utils/api.js — API Service Layer

All communication with the backend is centralised in api.js. This prevents scattered axios.get(...) calls across components and makes it easy to change the base URL.

Listing 2.7: api.js – Axios instance and helper

```
1 import axios from 'axios';  
2  
3 const API_URL = import.meta.env.VITE_API_URL || 'http://  
  localhost:5000/api';  
4  
5 const api = axios.create({ baseURL: API_URL });  
6  
7 // Attach JWT token to every request automatically  
8 api.interceptors.request.use(config => {  
9   const token = localStorage.getItem('token');  
10   if (token) config.headers.Authorization = `Bearer ${token}`;  
11   return config;  
12 });
```

```

13
14 // Generic helpers
15 export const get = (url, params) => api.get(url, { params });
16 export const post = (url, data) => api.post(url, data);
17
18 // Domain-specific helpers
19 export const getDestinations = () => get('/destinations
    ');
20 export const getDestinationById = (id) => get('/destinations
    /${id}');
21 export const createDestination = (data) => post('/
    destinations', data);
22 export const loginUser = (data) => post('/users/login
    ', data);
23 export const registerUser = (data) => post('/users',
    data);
24 // ... and many more

```

The Axios request interceptor automatically injects the Authorization: Bearer <token> header on every outgoing request if a token is found in localStorage, so protected API calls require no special handling at the call-site.

2.6 Page Components (pages/)

The application contains 16 page-level components. Each page is a React function component rendered when the corresponding route is matched.

File	Description
HomePage.jsx	Landing page with hero banner, featured destinations, and call-to-action buttons.
ExplorePage.jsx	District-based browsing with filter controls; lists all 25 Sri Lankan districts.
DestinationPage.jsx	Detailed view of a single destination: images, description, comments, ratings, and location map.
DistrictPage.jsx	Shows all destinations within a selected district with a district map.
AddDestinationPage.jsx	Multi-field form (title, description, images, coordinates, best time, tips) for authenticated users to add new destinations.
EditDestinationPage.jsx	Pre-filled form allowing destination authors to update or delete their entries.
LoginPage.jsx	Email/password login form with error feedback; redirects on success.

RegisterPage.jsx	Registration form (name, email, password); validates and calls registerUser().
ProfilePage.jsx	Displays user info, allows updating name/password/profile picture.
TravelGuidePage.jsx	Lists travel guides categorised by topic (planning, budget, visa, safety, etc.).
PhotoGalleryPage.jsx	Masonry-style gallery of all destination images.
LocalServicesPage.jsx	Directory of local services filterable by category (restaurant, hotel, transport, tour operator).
WeatherClimatePage.jsx	Displays real-time weather data for Sri Lankan cities.
AboutPage.jsx	Static information page about the platform.
AllDestinationsPage.jsx	Paginated list of all destinations with search and sort.
NotFoundPage.jsx	404 error page shown for unrecognised routes.

2.7 Shared Components (components/)

2.7.1 Header.jsx

The navigation bar renders differently based on screen size (responsive) and authentication state:

- On **desktop**, a horizontal menu bar shows all primary navigation links.
- On **mobile**, a hamburger button opens a slide-in drawer with the same links.
- When a user is **logged in**, an avatar/profile menu is shown with options to view the profile or log out.
- When **logged out**, Login and Register buttons are displayed.

2.7.2 Footer.jsx

A simple site footer with links to key sections, social media icons (from MUI icons), and copyright information.

2.7.3 DestinationCard.jsx

A reusable MUI Card component that displays a destination's thumbnail image, title, district, short description, and a link to the full destination page. Used in ExplorePage and AllDestinationsPage.

2.7.4 SriLankaMap.jsx

An interactive map powered by mapbox-gl via the react-map-gl React wrapper. It:

- Renders a styled base map centred on Sri Lanka.
- Plots markers for each destination using the latitude/longitude from the database.
- Shows a popup with the destination name and a link on marker click.

Chapter 3

Backend Server (server/)

3.1 Overview

The backend is a `Node.js` / `Express.js` REST API that handles all business logic, data persistence, authentication, and file uploads. It follows the classic MVC (Model-View-Controller) pattern adapted for a REST API: Models define data structure and database interaction; Controllers contain business logic; Routes map HTTP endpoints to controller functions.

The server listens on port 5000 and exposes all endpoints under the `/api` prefix.

3.2 `server.js` — Application Entry Point

`server.js` bootstraps the entire backend application. Its responsibilities are:

1. **Load environment variables** - `dotenv.config()` reads `.env` before anything else, making database credentials and the JWT secret available via `process.env`.
2. **Create Express app** - Initialises Express and registers global middleware.
3. **CORS configuration** - Allows cross-origin requests from any origin (`origin: '*'`) during development, with credentials enabled. This is necessary because the frontend and backend run on different origins (ports or domains).
4. **Body parsing** - `express.json()` and `express.urlencoded()` parse incoming JSON and form-encoded request bodies.
5. **Cache-Control headers** - A custom middleware adds `no-store`, `no-cache` headers to all `/api` responses, preventing browsers from caching API responses and serving stale data.
6. **Static file serving** - `express.static('uploads')` makes the `/uploads` directory publicly accessible so the frontend can display user-uploaded images.
7. **Route mounting** - Each feature area has its own router mounted at a sub-path (e.g. `/api/users`, `/api/destinations`).

8. **Database connection with retry** - Connects to MySQL using Sequelize with up to 3 retries and a 5-second backoff. If the database is unavailable, the server still starts and returns errors on database-dependent routes.
9. **Server startup** - `app.listen(PORT)` starts the HTTP server on the configured port.

Listing 3.1: server.js – Startup sequence (simplified)

```
1  const app = express();
2
3  // Middleware
4  app.use(cors({ origin: '*', credentials: true }));
5  app.use(express.json());
6  app.use('/uploads', express.static(path.join(__dirname, '
   uploads')));
7
8  // Routes
9  app.use('/api/users',          userRoutes);
10 app.use('/api/destinations',   destinationRoutes);
11 app.use('/api/districts',     districtRoutes);
12 app.use('/api/comments',      commentRoutes);
13 app.use('/api/ratings',       ratingRoutes);
14 app.use('/api/local-services', localServiceRoutes);
15 app.use('/api/travel-guides', travelGuideRoutes);
16 app.use('/api/weather',       weatherRoutes);
17
18 // Start server
19 connectDB().then(() => {
20   app.listen(5000, () => console.log('Server running on port
   5000'));
21 });
```

3.3 config/database.js — Database Configuration

This module exports a configured Sequelize instance that connects to MySQL using credentials from environment variables:

Listing 3.2: config/database.js

```
1  const sequelize = new Sequelize(
2    process.env.DB_NAME,
3    process.env.DB_USER,
4    process.env.DB_PASSWORD,
5    {
6      host:      process.env.DB_HOST,
7      dialect:   'mysql',
8      port:      process.env.DB_PORT || 3306,
9      logging:   false,           // Suppress SQL logs in
   production
10     pool: {
11       max: 10, min: 0,
```

```
12     acquire: 30000,  
13     idle: 10000  
14   }  
15 }  
16 );
```

The **connection pool** allows multiple simultaneous database queries without opening a new connection for every request, improving performance under load.

3.4 Database Models (models/)

Sequelize models define the database schema using JavaScript classes. Each model maps to a MySQL table. The `models/index.js` file imports all models and defines the **associations** (relationships) between them.

3.4.1 User Model

The User model stores account information and handles password security:

- **Fields:** `name` (STRING), `email` (STRING, unique), `password` (STRING), `profilePicture` (STRING, nullable), `isAdmin` (BOOLEAN, default false).
- **Password hashing hooks:** A `beforeCreate` and `beforeUpdate` Sequelize lifecycle hook automatically hashes the password using `bcryptjs` with 10 salt rounds whenever a user is created or their password is changed. This means the plain-text password is *never* stored in the database.
- **`matchPassword()`** - An instance method that compares a plain-text candidate password against the stored hash using `bcryptjs.compare()`, used during login.

3.4.2 District Model

Represents the 25 districts of Sri Lanka:

- **Fields:** `name` (STRING, unique), `description` (TEXT), `mapCoordinates` (JSON -- lat/lng bounds), `imageUrl` (STRING), `province` (STRING).
- Districts are the top-level geographical grouping. Each district can contain many destinations.

3.4.3 Destination Model

The core entity of the application:

- **Fields:** `title`, `description` (TEXT), `images` (JSON array of file paths), `location` (JSON with lat/lng), `bestTimeToVisit` (STRING), `travelTips` (TEXT).
- **Foreign keys:** `districtId` (belongs to District, CASCADE delete -- if the district is deleted, all its destinations are deleted too), `authorId` (belongs to User).

- Images are stored as an array of file paths, allowing multiple photos per destination.

3.4.4 Comment Model

Stores user comments on destinations:

- **Fields:** content (TEXT, required).
- **Relations:** belongs to User and Destination. If the parent destination is deleted, all its comments are deleted (CASCADE).

3.4.5 Rating Model

Stores 1-5 star ratings submitted by users for destinations:

- **Fields:** value (INTEGER, validated: min 1, max 5).
- A user can rate the same destination only once (unique constraint on `userId` + `destinationId`).

3.4.6 LocalService Model

A rich model for the local services directory:

- **category ENUM:** restaurant | hotel | transport | tour-operator | other.
- **priceRange ENUM:** \$ | \$\$ | \$\$\$ | \$\$\$\$ (budget to luxury).
- **JSON arrays:** features, specialties, amenities, services allow rich structured data without needing separate join tables.
- **isVerified** flag to distinguish officially verified listings from user-submitted ones.

3.4.7 TravelGuide Model

Stores user-contributed and official travel guides:

- **category ENUM:** planning | transport | budget | cultural | safety | visa | emergency | language | other.
- **JSON tags** array for flexible tagging.
- **viewCount** / **helpfulCount** counters to surface the most useful guides.
- **isOfficial** / **isVerified** flags to distinguish platform-curated content from community submissions.

3.4.8 Model Relationships

Listing 3.3: models/index.js – Association definitions

```
1 // District -> Destination: one district has many destinations
2 District.hasMany(Destination, { foreignKey: 'districtId',
  onDelete: 'CASCADE' });
```

```
3 Destination.belongsTo(District, { foreignKey: 'districtId' });
4
5 // User -> Destination: a user can author many destinations
6 User.hasMany(Destination, { foreignKey: 'authorId', as:
  'destinations' });
7 Destination.belongsTo(User, { foreignKey: 'authorId', as:
  'author' });
8
9 // User/Destination -> Comments
10 User.hasMany(Comment, { foreignKey: 'userId' });
11 Destination.hasMany(Comment, { foreignKey: 'destinationId'
  , onDelete: 'CASCADE' });
12 Comment.belongsTo(User, { foreignKey: 'userId' });
13 Comment.belongsTo(Destination, { foreignKey: 'destinationId'
  });
14
15 // User/Destination -> Ratings
16 User.hasMany(Rating, { foreignKey: 'userId' });
17 Destination.hasMany(Rating, { foreignKey: 'destinationId'
  , onDelete: 'CASCADE' });
18
19 // User -> LocalServices
20 User.hasMany(LocalService, { foreignKey: 'userId' });
21
22 // User -> TravelGuides
23 User.hasMany(TravelGuide, { foreignKey: 'userId', as: '
  guides' });
```

3.5 Controllers (controllers/)

Controllers contain the business logic for each feature area. They receive (req, res) from Express routes, interact with Sequelize models, and send back JSON responses.

3.5.1 userController.js

- **registerUser** - Validates email uniqueness, creates a User record (password is hashed automatically by the model hook), returns the new user and a JWT token.
- **loginUser** - Finds user by email, calls `matchPassword()` to verify the password, returns user data and a signed JWT (30-day expiry).
- **getUserProfile** - Returns the authenticated user's profile (protected by `authMiddleware`).
- **updateUserProfile** - Allows updating name, password, and profile picture (file upload handled by Multer middleware).

3.5.2 destinationController.js

- **getDestinations** - Returns all destinations with associated District and author User data (eager loading with Sequelize's include). Supports filtering by districtId query parameter.
- **getDestinationById** - Returns a single destination with its comments (including commenter name), average rating, and associated district.
- **createDestination** - Creates a new destination. Images are saved to disk by Multer and their paths stored as a JSON array.
- **updateDestination** - Updates an existing destination; checks that the requester is the author or an admin.
- **deleteDestination** - Deletes a destination and cascades to comments and ratings.
- **removeDestinationImage** - Removes a single image from a destination's images array by index.

3.5.3 districtController.js

Provides simple read operations for the District table: list all districts and retrieve a single district by ID (including associated destinations).

3.5.4 commentController.js

- **addComment** - Authenticated users can post a comment on a destination.
- **updateComment** - Users can edit their own comments.
- **deleteComment** - Users can delete their own comments (admins can delete any comment).
- **getCommentsByDestination** - Retrieves all comments for a destination, including the author's name and profile picture.

3.5.5 ratingController.js

- **submitRating** - Creates or updates the authenticated user's rating for a destination (upsert behaviour).
- **getAverageRating** - Computes and returns the average rating for a destination.

3.5.6 localServiceController.js

Full CRUD for the local services directory. Supports rich filtering: by category, by district, by price range, and free-text search.

3.5.7 travelGuideController.js

Full CRUD for travel guides. Supports filtering by category, sorting by view count or helpful count, and incrementing the viewCount when a guide is read.

3.5.8 weatherController.js

Delegates to weatherService.js to fetch live weather data and returns it to the frontend. Caches results to avoid excessive external API calls.

3.6 Routes (routes/)

Route files use Express Router to define HTTP method + path pairs and connect them to controller functions. Some routes apply the authMiddleware and/or uploadMiddleware.

Table 3.1: Key API endpoints

Method + Path	Controller function	Auth?
POST /api/users	registerUser	No
POST /api/users/login	loginUser	No
GET /api/users/profile	getUserProfile	Yes
PUT /api/users/profile	updateUserProfile	Yes + Upload
GET /api/destinations	getDestinations	No
GET /api/destinations/:id	getDestinationById	No
POST /api/destinations	createDestination	Yes + Upload
PUT /api/destinations/:id	updateDestination	Yes
DELETE /api/destinations/:id	deleteDestination	Yes
GET /api/districts	getAllDistricts	No
GET /api/districts/:id	getDistrictById	No
POST /api/comments	addComment	Yes
PUT /api/comments/:id	updateComment	Yes
DELETE /api/comments/:id	deleteComment	Yes
POST /api/ratings	submitRating	Yes
GET /api/local-services	getLocalServices	No
GET /api/travel-guides	getTravelGuides	No
GET /api/weather/:city	getWeather	No

3.7 Middleware (middleware/)

3.7.1 authMiddleware.js — JWT Verification

This middleware protects routes that require a logged-in user:

Listing 3.4: authMiddleware.js

```

1 const protect = async (req, res, next) => {
2   let token;
3   if (req.headers.authorization?.startsWith('Bearer ')) {
4     token = req.headers.authorization.split(' ')[1];
5   }
6   if (!token) {
7     return res.status(401).json({ message: 'Not authorised, no token' });
8   }
9 }

```

```
8   }
9   try {
10     const decoded = jwt.verify(token, process.env.JWT_SECRET);
11     req.user = await User.findByPk(decoded.id,
12       { attributes: { exclude: ['password'] } });
13     next();
14   } catch (error) {
15     res.status(401).json({ message: 'Not authorised, token
16       failed' });
17   }
18 };
```

The middleware reads the token from the Authorization header, verifies it against the JWT_SECRET environment variable, and attaches the decoded user object to req.user so downstream controllers can access it.

3.7.2 uploadMiddleware.js — File Upload Handling

Built on Multer, this middleware handles multipart/form-data file uploads:

- **Storage** - Files are saved to the server/uploads/ directory with a unique timestamp-based filename to prevent collisions.
- **File filter** - Only image MIME types (image/jpeg, image/png, image/gif, image/webp) are accepted; other file types are rejected with a 400 error.
- **Size limit** - Individual files are capped at 5MB.
- Two upload configurations are exported: uploadSingle (profile pictures) and uploadMultiple (up to 10 destination images).

3.8 services/weatherService.js — External Weather Integration

weatherService.js encapsulates all interaction with the external weather API (e.g. OpenWeatherMap). It:

- Constructs API requests with the city name and API key (from environment variables).
- Normalises the API response into a consistent internal format.
- Implements a simple in-memory cache to avoid repeated API calls for the same city within a short window.

3.9 Dockerfile_backend

Listing 3.5: Backend Dockerfile (simplified)

```
1 FROM node:18-alpine
2 WORKDIR /app
```

```
3 COPY package*.json ./
4 RUN npm install --production    # Only production dependencies
5 COPY . .
6 RUN mkdir -p uploads            # Ensure uploads directory
  exists
7 EXPOSE 5000
8 HEALTHCHECK --interval=30s --timeout=10s \
9   CMD wget -qO- http://localhost:5000/api/test || exit 1
10 CMD ["node", "server.js"]
```

The HEALTHCHECK directive allows Docker (and Docker Compose) to detect if the backend has crashed or become unresponsive and restart it automatically.

Chapter 4

Database Design

4.1 Overview

The application uses MySQL 8.0 hosted on AWS RDS. The schema is managed by Sequelize ORM, which synchronises the JavaScript model definitions to the database tables. The database name is tour_blog.

4.2 Entity-Relationship Summary

Figure description (textual ER diagram):

Listing 4.1: Textual ER diagram

```
1 [User] ---1:N---> [Destination] (authorId)
2 [User] ---1:N---> [Comment]      (userId)
3 [User] ---1:N---> [Rating]       (userId)
4 [User] ---1:N---> [LocalService] (userId)
5 [User] ---1:N---> [TravelGuide]  (userId)
6
7 [District] ---1:N---> [Destination] (districtId, CASCADE)
8
9 [Destination] ---1:N---> [Comment] (destinationId, CASCADE)
10 [Destination] ---1:N---> [Rating]  (destinationId, CASCADE)
```

4.3 Table Definitions

Table 4.1: users table

Column	Type	Constraints	Description
id	INT	PK, AUTO_INCREMENT	Unique identifier
name	VARCHAR(255)	NOT NULL	Display name
email	VARCHAR(255)	NOT NULL, UNIQUE	Login email
password	VARCHAR(255)	NOT NULL	bcrypt hash
profilePicture	VARCHAR(255)	NULL	Upload file path
isAdmin	BOOLEAN	DEFAULT false	Admin flag
createdAt	DATETIME		Auto-managed
updatedAt	DATETIME		Auto-managed

Table 4.2: districts table

Column	Type	Constraints	Description
id	INT	PK, AUTO_INCREMENT	
name	VARCHAR(255)	NOT NULL, UNIQUE	District name
description	TEXT		
mapCoordinates	JSON		Lat/lng bounds
imageUrl	VARCHAR(255)		
province	VARCHAR(255)		Province name

Table 4.3: destinations table

Column	Type	Constraints	Description
id	INT	PK	
title	VARCHAR(255)	NOT NULL	
description	TEXT	NOT NULL	
images	JSON		Array of paths
location	JSON		{lat, lng}
bestTimeToVisit	VARCHAR(255)		
travelTips	TEXT		
districtId	INT	FK districts	
authorId	INT	FK users	

4.4 Data Seeding

The server directory contains several database utility scripts:

- `createDatabase.js` - Creates the `tour_blog` schema if it does not exist.
- `setupNewDatabase.js` - Runs schema synchronisation (`sequelize.sync()`).

- `seed.js` / `seedNewDatabase.js` - Populates the database with sample districts, destinations, and travel guides for demonstration purposes.
- `testConnection.js` / `mysqlCheck.js` - Utility scripts to verify that the application can reach the database before deployment.

Chapter 5

Docker and Containerisation

5.1 Overview

The entire application stack is containerised using **Docker**, enabling consistent behaviour across development, CI/CD, and production environments. All services are orchestrated locally using **Docker Compose**.

5.2 docker-compose.yml

The Compose file defines three services:

Listing 5.1: docker-compose.yml services

```
1 services:
2   mysql:
3     image: mysql:8.0
4     environment:
5       MYSQL_ROOT_PASSWORD: rootpassword
6       MYSQL_DATABASE: tour_blog
7       MYSQL_USER: admin
8       MYSQL_PASSWORD: password
9     ports: ["3306:3306"]
10    volumes: [mysql_data:/var/lib/mysql]
11    healthcheck:
12      test: ["CMD", "mysqladmin", "ping"]
13      interval: 30s
14      retries: 3
15
16    backend:
17      build:
18        context: ./server
19        dockerfile: Dockerfile_backend
20      ports: ["5000:5000"]
21      environment:
22        DB_HOST: mysql
23        DB_USER: admin
24        DB_PASSWORD: password
```

```
25     JWT_SECRET: dev-secret
26     depends_on:
27       mysql: { condition: service_healthy }
28     volumes: [./server/uploads:/app/uploads]
29
30 frontend:
31   build:
32     context: ./client
33     dockerfile: Dockerfile_frontend
34     args:
35       VITE_API_URL: http://localhost:5000/api
36   ports: ["80:80"]
37   depends_on: [backend]
```

Key points:

- **Health checks** - MySQL reports healthy only after accepting connections; the backend container waits for this (`condition: service_healthy`) to avoid startup race conditions.
- **Named volume** (`mysql_data`) - Persists MySQL data across container restarts so database contents survive docker compose down.
- **Uploads volume** - Mounts `./server/uploads` into the backend container so uploaded files persist and are accessible on the host.
- **Service networking** - Docker Compose creates a default bridge network; the backend connects to MySQL using the service name `mysql` as the hostname.

5.3 .dockerignore

The `.dockerignore` file excludes unnecessary files from the Docker build context (e.g. `node_modules`, `.git`, `dist`) to speed up image builds and reduce image sizes.

Chapter 6

CI/CD Pipeline (Jenkinsfile)

6.1 Overview

The Jenkins Declarative Pipeline automates the end-to-end build-and-deploy workflow. Every push to the repository triggers the pipeline, which:

1. Prepares the build environment.
2. Builds Docker images for both backend and frontend.
3. Pushes images to **Docker Hub** (under the upeka2002 account).
4. Installs Terraform if not already present.
5. Runs Terraform to apply any infrastructure changes on AWS.

6.2 Environment Variables

Listing 6.1: Jenkinsfile environment block

```
1 environment {  
2     DOCKERHUB_REPO    = "upeka2002"  
3     BACKEND_IMAGE     = "upeka2002/tourblog-backend"  
4     FRONTEND_IMAGE    = "upeka2002/tourblog-frontend"  
5     TF_VERSION        = "1.7.0"  
6 }
```

6.3 Pipeline Stages Explained

6.3.1 Stage 1: Prepare

Checks out the latest source code and generates a short **Git commit SHA** to use as the Docker image tag. Using the commit SHA (instead of latest) ensures every image is traceable to the exact code version:

Listing 6.2: Prepare stage

```
1 stage('Prepare') {
2   steps {
3     checkout scm
4     script {
5       IMAGE_TAG = sh(returnStdout: true,
6                     script: 'git rev-parse --short HEAD').
7       trim()
8       echo "Building image tag: ${IMAGE_TAG}"
9     }
10  }
```

6.3.2 Stage 2: Build Backend

Builds the backend Docker image from `./server/Dockerfile_backend`, tagging it with both the commit SHA and latest:

Listing 6.3: Build Backend stage

```
1 stage('Build Backend') {
2   steps {
3     dir('server') {
4       sh """
5         docker build -f Dockerfile_backend \
6           -t ${BACKEND_IMAGE}:${IMAGE_TAG} \
7           -t ${BACKEND_IMAGE}:latest .
8       """
9     }
10  }
11 }
```

6.3.3 Stage 3: Build Frontend

Builds the frontend Docker image. The AWS EC2 public IP is injected as a build argument so Vite embeds the correct API URL into the compiled JavaScript bundle:

Listing 6.4: Build Frontend stage

```
1 stage('Build Frontend') {
2   steps {
3     dir('client') {
4       sh """
5         docker build \
6           --build-arg VITE_API_URL=http://<EC2_PUBLIC_IP
7         >:5000/api \
8           -f Dockerfile_frontend \
9           -t ${FRONTEND_IMAGE}:${IMAGE_TAG} \
10          -t ${FRONTEND_IMAGE}:latest .
11       """
12     }
13  }
```

6.3.4 Stage 4: Push to Docker Hub

Authenticates with Docker Hub using Jenkins credentials and pushes both tagged images:

Listing 6.5: Push to Docker Hub stage

```
1 stage('Push to Docker Hub') {
2     steps {
3         withCredentials([usernamePassword(
4             credentialsId: 'dockerhub-credentials',
5             usernameVariable: 'DOCKER_USER',
6             passwordVariable: 'DOCKER_PASS'
7         )]) {
8             sh """
9                 echo "$DOCKER_PASS" | docker login -u "$DOCKER_USER"
10                --password-stdin
11                docker push ${BACKEND_IMAGE}:${IMAGE_TAG}
12                docker push ${BACKEND_IMAGE}:latest
13                docker push ${FRONTEND_IMAGE}:${IMAGE_TAG}
14                docker push ${FRONTEND_IMAGE}:latest
15                docker logout
16            """
17        }
18    }
19 }
```

Security note: The password is never echoed; `--password-stdin` reads it from stdin.

6.3.5 Stage 5: Install Terraform

Checks if Terraform is installed; if not, downloads version 1.7.0 from the official HashiCorp releases:

Listing 6.6: Install Terraform stage

```
1 stage('Install Terraform') {
2     steps {
3         sh """
4             if ! command -v terraform &>/dev/null; then
5                 wget https://releases.hashicorp.com/terraform/${
6                     TF_VERSION
7                 }/
8                 terraform_${TF_VERSION}_linux_amd64.zip
9                 unzip terraform_${TF_VERSION}_linux_amd64.zip
10                mv terraform /usr/local/bin/
11            fi
12            terraform version
13        """
14    }
15 }
```


6.3.6 Stages 6–9: Terraform Init, State Cleanup, Plan, Apply

These stages use the AWS credentials stored in Jenkins (aws-access-key-id and aws-secret-access-key) to authenticate with AWS and apply infrastructure changes:

- **Terraform Init** - Downloads the AWS provider plugin and initialises the working directory.
- **State Cleanup** - Removes stale resource entries from the Terraform state file to avoid errors with pre-existing resources.
- **Terraform Plan** - Generates an execution plan (tfplan) showing exactly what changes will be made to AWS.
- **Terraform Apply** - Applies the plan automatically (-auto-approve), updating S3 bucket configuration.

Chapter 7

Infrastructure as Code (Terraform.tf)

7.1 Overview

Terraform.tf defines and manages the AWS cloud infrastructure required to run the Tour Blog platform in production. It uses the HashiCorp Configuration Language (HCL) and the hashicorp/aws provider (~5.0).

A key design decision is that Terraform references existing AWS resources (by their IDs) rather than creating them from scratch. This prevents accidental destruction of live infrastructure while still allowing Terraform to manage configuration (e.g. S3 policies).

7.2 Provider Configuration

Listing 7.1: Provider block

```
1 terraform {
2   required_version = ">= 1.0"
3   required_providers {
4     aws = {
5       source  = "hashicorp/aws"
6       version = "~> 5.0"
7     }
8   }
9 }
10
11 provider "aws" {
12   region = var.aws_region # Default: us-east-1
13 }
```

The AWS credentials are supplied at runtime via environment variables (AWS_ACCESS_KEY_ID and AWS_SECRET_ACCESS_KEY) injected by Jenkins, keeping secrets out of the repository.

7.3 Referenced Existing Resources

The following resources are referenced using data sources but **not** managed (not created or destroyed) by Terraform:

- **EC2 instance** (`<EC2_INSTANCE_ID>`) `~Ubuntu22.04LTSt3.microinstancerunningtheDocker`
- **S3 buckets** - `tour-blog-frontend-<ACCOUNT_ID>` and `tour-blog-deploy-<ACCOUNT_ID>`.

7.4 Managed Resources

Terraform actively manages three S3 resources:

1. **S3 Website Configuration** - Configures the frontend bucket as a static website with `index.html` as both index and error document, enabling React Router to serve all routes.
2. **S3 Public Access Block** - Disables all four AWS public-access blocks on the frontend bucket, allowing the bucket policy to grant public read access.
3. **S3 Bucket Policy** - Attaches an IAM policy granting `s3:GetObject` to all principals ("`*`") on all objects in the bucket, making static assets publicly readable.

7.5 Input Variables

Table 7.1: Terraform input variables

Variable	Type	Default	Sensitive
<code>aws_region</code>	string	<code>us-east-1</code>	No
<code>project_name</code>	string	<code>tour-blog</code>	No
<code>ec2_ami_id</code>	string	<code><AMI_ID></code>	No
<code>ec2_instance_type</code>	string	<code>t3.micro</code>	No
<code>ssh_public_key</code>	string	<code>(empty)</code>	Yes
<code>db_engine_version</code>	string	<code>8.0.40</code>	No
<code>db_instance_class</code>	string	<code>db.t3.micro</code>	No
<code>db_allocated_storage</code>	number	<code>20</code>	No
<code>db_name</code>	string	<code>tour_blog</code>	No
<code>db_username</code>	string	<code>admin</code>	Yes
<code>db_password</code>	string	<code>(empty)</code>	Yes

7.6 Outputs

After a `terraform apply`, the following values are printed, allowing other tools (e.g. the Jenkins deploy stage) to discover the infrastructure endpoints dynamically:

Table 7.2: Terraform outputs

Output	Value
ec2_public_ip	Public IP of the backend server
ec2_instance_id	AWS instance ID
ec2_ssh_command	Ready-to-use SSH command
rds_endpoint	Full RDS connection string (host:port)
rds_address	RDS hostname only
database_name	tour_blog
backend_api_url	http://{ec2_ip}:5000/api
s3_frontend_url	S3 static website URL

7.7 user-data-inline.sh — EC2 Bootstrap Script

This Bash script is executed once when the EC2 instance first launches (via AWS User Data). It automates the entire server setup:

1. System update (apt-get update && upgrade)
2. Install Node.js 20.x from NodeSource
3. Install PM2 globally (npm install -g pm2) -- process manager
4. Install MySQL client, Git, unzip
5. Download and install AWS CLI v2
6. Create /app directory with correct permissions
7. Generate .env template for the backend
8. Create a deployment shell script that pulls Docker images and restarts containers

7.8 cleanup-terraform-state.sh

A utility script for Terraform state management. It removes stale resource references from the local Terraform state file (terraform.tfstate), preventing "resource already exists" errors when Terraform tries to manage resources that were created outside of Terraform. This is particularly useful during initial setup or after manual AWS console changes.

Chapter 8

Authentication and Security

8.1 Authentication Flow

The application uses **stateless** JWT (JSON Web Token) authentication:

1. User submits email and password via POST `/api/users/login`.
2. Backend finds the user by email, calls `user.matchPassword(plaintext)` which calls `bcryptjs.compare()`.
3. If the password matches, the server calls `jwt.sign({ id, name, email }, JWT_SECRET, { expiresIn: '30d' })` to produce a signed token.
4. The token is returned to the frontend in the response body.
5. The frontend stores the token in `localStorage` and includes it as `Authorization: Bearer <token>` on every subsequent request.
6. The `authMiddleware` verifies the token signature on protected routes.

8.2 Password Security

Passwords are hashed using **bcryptjs** with a cost factor (salt rounds) of 10. This means:

- Plain-text passwords are **never stored** in the database.
- Each password hash is unique due to random salt, preventing rainbow table attacks.
- The cost factor of 10 means ~1024 hash iterations, making brute-force attacks computationally expensive.

8.3 Security Headers (Nginx)

The Nginx configuration adds HTTP security headers to all frontend responses:

- X-Frame-Options: SAMEORIGIN -- Prevents clickjacking by blocking the page from being embedded in iframes on other domains.
- X-Content-Type-Options: nosniff -- Prevents MIME-type sniffing attacks.
- X-XSS-Protection: 1; mode=block -- Enables the browser's built-in XSS filter.

8.4 Security Considerations and Recommendations

Table 8.1: Security assessment

Area	Status	Notes
Password hashing	Implemented	bcryptjs, 10 rounds
JWT authentication	Implemented	30-day expiry
CORS	Partially	All origins allowed (tighten for production)
HTTPS	Not shown	Recommend AWS CloudFront + ACM
Rate limiting	Missing	Recommend express-rate-limit
Input validation	Basic	Add express-validator
SQL injection	Protected	Sequelize ORM parameterises queries
XSS (frontend)	Partial	React escapes JSX; add CSP header

Chapter 9

Deployment Workflow

9.1 End-to-End Deployment Sequence

1. Developer pushes code to the GitHub repository.
2. GitHub Webhook triggers the Jenkins pipeline.
3. Jenkins (Stage: Prepare) checks out code, computes commit SHA for image tagging.
4. Jenkins (Stage: Build Backend) builds upeka2002/tourblog-backend:{sha}.
5. Jenkins (Stage: Build Frontend) builds upeka2002/tourblog-frontend:{sha} with the EC2 IP embedded.
6. Jenkins (Stage: Push) authenticates with Docker Hub and pushes both images.
7. Jenkins (Stage: Terraform Apply) updates S3 bucket configuration.
8. Deploy script on EC2 pulls the new latest images and restarts Docker containers.
9. Health check confirms the backend API is responding.

9.2 Local Development

Listing 9.1: Starting the application locally

```
1 # Clone the repository
2 git clone https://github.com/UpekaFernando/
   tour_blog_info_final.git
3 cd tour_blog_info_final
4
5 # Start all services (MySQL + backend + frontend)
6 docker compose up -d --build
7
8 # View backend logs
9 docker compose logs -f backend
10
11 # Stop all services
```

```
12 docker compose down
```

After docker compose up, the application is accessible at:

- Frontend: `http://localhost:80`
- Backend API: `http://localhost:5000/api`

9.3 Environment Variables Reference

Table 9.1: Required environment variables

Variable	Service	Description
DB_HOST	Backend	MySQL hostname
DB_USER	Backend	MySQL username
DB_PASSWORD	Backend	MySQL password
DB_NAME	Backend	Database name (<code>tour_blog</code>)
DB_PORT	Backend	MySQL port (default 3306)
JWT_SECRET	Backend	Secret for signing JWT tokens
NODE_ENV	Backend	<code>development</code> or <code>production</code>
PORT	Backend	Server port (default 5000)
VITE_API_URL	Frontend (build)	Backend API base URL

Chapter 10

Summary and Conclusions

10.1 What Has Been Built

The Tour Blog platform is a **production-ready, cloud-deployed full-stack web application** covering the complete spectrum of modern software engineering:

- A **React SPA** with Material Design UI, client-side routing, interactive mapping, and responsive layout.
- A **Node.js/Express REST API** with MVC architecture, JWT authentication, file uploads, and comprehensive CRUD endpoints for 6 domain entities.
- A **MySQL relational database** with 7 interconnected tables managed by the Sequelize ORM.
- **Docker containerisation** for consistent environments and simplified deployment.
- A **Jenkins CI/CD pipeline** that automates the entire build → push → deploy cycle.
- **Terraform infrastructure-as-code** managing AWS resources (EC2, RDS, S3).

10.2 Key Design Decisions

1. **Separation of concerns** - Frontend and backend are completely independent services communicating only via HTTP API, enabling independent scaling and deployment.
2. **Environment-based configuration** - All sensitive values (passwords, secrets, API keys) are injected via environment variables, never hard-coded.
3. **Stateless authentication** - JWT tokens allow horizontal scaling of the backend without shared session storage.
4. **Terraform data sources** - Referencing existing AWS resources (rather than recreating them) protects production data from accidental destruction.
5. **Docker multi-stage builds** - Keeps production images small and secure by excluding development tooling.

10.3 Future Improvements

- **HTTPS** - Configure AWS CloudFront with an ACM certificate in front of both the EC2 instance and S3 bucket.
- **CORS hardening** - Restrict allowed origins to the specific frontend domain.
- **Rate limiting** - Add express-rate-limit to prevent API abuse.
- **Image storage** - Move uploaded images from local disk to AWS S3 for durability and scalability.
- **Testing** - Add unit tests (Jest) for controllers and integration tests (Supertest) for API endpoints.
- **Monitoring** - Integrate AWS CloudWatch metrics and alerts.
- **Database migrations** - Use Sequelize migrations (instead of `sync()`) for controlled schema changes in production.